

NORTHSTAR FINANCIAL SERVICES

VENDOR RISK MANAGEMENT & THIRD-PARTY LIFECYCLE POLICY V3.0

DOCUMENT ID	EFFECTIVE DATE	POLICY OWNER	CLASSIFICATION
POL-VRM-2025-03	Aug 15, 2025	Enterprise Risk Management (ERM)	Internal Confidential

1. PURPOSE & EXECUTIVE MANDATE

Northstar Financial Services (NFS) interacts with hundreds of technology vendors, cloud providers, and AI platforms. This policy mandates the comprehensive risk identification, scoring, mitigation, and continuous monitoring framework required to protect NFS against operational, financial, legal, and systemic cybersecurity risks introduced by third parties.

2. UNIFIED VENDOR RISK SCORING MATRIX

The multi-agent evaluation system aggregates findings from Procurement, InfoSec, Legal, Finance, and AI Governance into a composite **Vendor Risk Score (VRS)** ranging from 0 to 100. Vendor authorization is governed by the following scoring thresholds:

RISK LEVEL	COMPOSITE VRS SCORE	OPERATIONAL STATUS	APPROVAL AUTHORITY
Low Risk	0 – 25 points	Approved for standard onboarding & rapid deployment.	Procurement Lead & Domain Agents.
Moderate Risk	26 – 50 points	Conditional approval requiring targeted mitigation clauses.	Department Head & Risk Officer.
High Risk	51 – 75 points	Executive review required with mandatory compensating controls.	Enterprise Risk Committee (ERC).
Critical / Veto	76 – 100 points OR any Veto Trigger	Immediate Rejection. No contract execution permitted.	Chief Risk Officer & CISO (Non-waivable).

3. FOURTH-PARTY & SUPPLY CHAIN SUBPROCESSOR GOVERNANCE

Vendors often rely on downstream cloud infrastructure (AWS, Azure, GCP) and specialized sub-vendors (API gateways, OCR engines, LLM providers). Risk evaluation extends to fourth-party dependencies:

- Subprocessor Disclosure:** Vendors must maintain an up-to-date registry of all subcontractors handling NFS data and provide 30 days advance notice before adding new subprocessors.
- Flow-Down Protections:** Vendors are contractually obligated to flow down all NFS security, data residency, privacy, and confidentiality obligations to all fourth-party subcontractors.

Risk Rule: If a vendor utilizes an unvetted fourth-party AI provider or cloud region located outside the US/EU without explicit prior approval, the vendor risk score automatically elevates to Critical, triggering an unappealable veto.

4. CONTINUOUS MONITORING & ANNUAL RE-ASSESSMENT

Vendor risk management does not end at onboarding. NFS enforces ongoing lifecycle monitoring to detect emerging vulnerabilities, financial distress, or compliance drift:

MONITORING CADENCE	EVALUATION FOCUS AREA	ACTION TRIGGER
Continuous Automated	Perimeter security posture, TLS validity, leaked credentials, public CVE disclosures, and threat intelligence feeds.	Instant alert to InfoSec Agent upon CVSS > 7.0 detection.
Quarterly Financial Check	Credit rating updates, public bankruptcy filings, litigation alerts, and Dun & Bradstreet stability scores.	Mandatory review if Altman Z-Score dips below 1.81 (Distress Zone).
Annual Comprehensive	Recertification of SOC 2 Type II, updated penetration test summaries, insurance policy renewals, and compliance attestations.	Full multi-agent re-evaluation 30 days prior to contract anniversary.

5. VENDOR RISK MANAGEMENT RED-LINES & VETO CRITERIA

The Enterprise Risk Management framework defines immutable red-lines that result in an immediate vendor disqualification:

VETO Uninsured Cyber Liabilities Vendor maintains less than \$10,000,000 in aggregate Technology Errors & Omissions (E&O) and Cyber Liability insurance coverage.	VETO Refusal of Right-to-Audit Vendor contractually restricts NFS or its designated independent regulators from reviewing security logs, compliance records, or facilities.
REQUIRED Business Continuity & DR Mandatory annual testing of Disaster Recovery (DR) and Business Continuity Plans (BCP) with a Recovery Point Objective (RPO) < 1 hour.	REQUIRED Transition Assistance SLA Vendor must commit to 90 days of seamless data export and transition assistance upon contract termination at pre-agreed rates.

6. OFFBOARDING & DATA DECOMMISSIONING PROTOCOL

When a vendor contract expires or is terminated:

- Destruction Certification:** Vendor must provide an official Certificate of Destruction confirming complete purging of all NFS data in accordance with NIST SP 800-88 standards within 30 days.
- Access Revocation:** Immediate termination of all API tokens, SSO federations, and network tunnels.